

# The Skateboard: System Architecture

## Components, Communication, and the Trust Firewall

Companion to `skateboard.tex`

Original design: July 30, 2026; implementation revision: September 6, 2026

**Document status.** This paper began as the pre-implementation architecture proposal. It now keeps that rationale while distinguishing it from the repository as implemented. Statements introduced as “current” describe the September 2026 code. Future cluster deployment, automatic strategy ladders, model adapters, and enforced retry or held-out-query budgets remain proposals. The source tree and the version-2 evidence contract are authoritative when this paper and an older PDF disagree.

## 1 What this document decides

The design note `skateboard.tex` records the original scope and rationale. This document describes the concrete implementation and identifies the parts of the original plan that remain future work. The current deployment runs on one computer. Moving it to a cluster should preserve the HTTP contracts, but would still require deployment, authentication, storage, and threat-model work.

One idea shapes every choice. **The AI agent is untrusted.** In the current system it is an interactive coding session, not a pure function: it edits the working copy and calls the gateway through a small tool extension. It cannot write the repository or ledger, connect to the builder or oracle networks, or mint claims from its own terminal output. The gateway chooses the action table, checks prerequisites, resolves the submitted Git commit, and is the only service that can ask the builder or oracle to act. Network topology, read-only mounts, protected evidence directories, and disposable jobs enforce this boundary.

## 2 The components

The deployed core has four services plus persistent state. Optional walkthrough containers exercise the same public gateway path, and the model provider is external. Table 1 lists the core responsibilities.

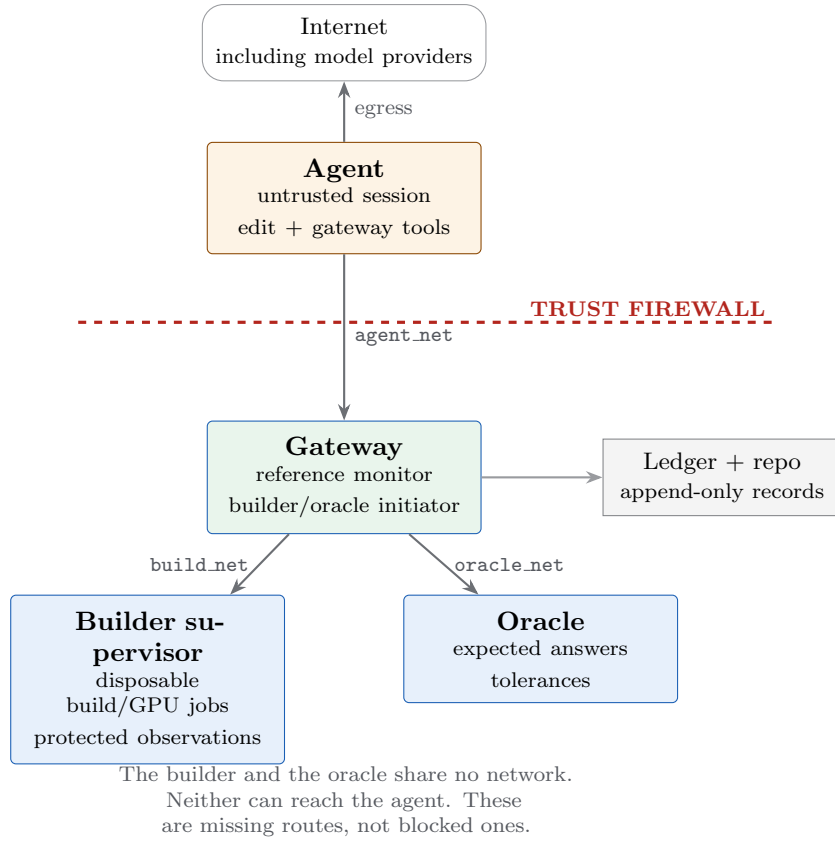
## 3 How the parts are wired

Figure 1 shows the shape of the system. The gateway sits in the middle. It is the only service on all three internal networks. The builder and the oracle each sit on their own private network. They cannot talk to each other. They can only answer the gateway. The agent sits above a line we call the trust firewall. It can reach the internet to call a model and can call the gateway on `agent.net`; it has no route to the builder or oracle networks.

Each network is a separate Docker network, with isolation enforced by the Docker daemon and host networking rules. The agent container has no interface on the builder or oracle network and

| <b>Part</b>               | <b>Its one job</b>                                                                                                                                                                                        | <b>Networks</b>      | <b>Trust</b>                            |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------|-----------------------------------------|
| <b>Gateway</b>            | Reference monitor. Accepts submissions and action requests, enforces phase and evidence prerequisites, filters receipts, and writes the ledger.                                                           | agent, build, oracle | Trusted core                            |
| <b>Agent</b>              | Interactive coding session. Edits the configured working copy and invokes only the gateway tools exposed for its region.                                                                                  | agent, egress        | <b>Untrusted</b>                        |
| <b>Builder supervisor</b> | Receives a committed tree and reviewed strategy, launches restricted disposable build/run jobs, and returns protected compiler, binary, profiler, sanitizer, property, mutation, and timing observations. | build only           | Trusted worker and Docker control plane |
| <b>Oracle</b>             | Holds the expected answers and the tolerances. Answers one question: do these numbers match? It runs no code from the agent.                                                                              | oracle only          | Trusted, sealed                         |
| <b>Ledger + repo</b>      | Append-only request and claim records, content-addressed artifacts, and immutable Git commits for submitted candidates. Host storage mounted only into the gateway.                                       | none                 | Trusted data                            |
| <b>Model provider</b>     | External provider reached from the agent’s egress network. A local server remains an optional deployment.                                                                                                 | egress               | Outside the evidence trust boundary     |

**Table 1:** The deployed responsibilities. The agent is untrusted. It shares no network or disk with the builder, oracle, repository, or ledger; the gateway sees its working copy through a read-only mount.



**Figure 1:** The current topology (the original “orchestrator” box is now the gateway reference monitor). The agent crosses the trust boundary only through the gateway API. The builder and oracle are on separate private networks with no route from the agent or to each other.

no direct route to those services. This network boundary complements the read-only mounts and filesystem permissions that protect the ledger, original references, and observer artifacts.

The services also check a deployment bearer token. The agent receives that token for gateway calls, and the current deployment reuses it for internal services. It authenticates membership in this deployment; it is not a second isolation barrier. A network misconfiguration that routed the agent directly to the builder or oracle would therefore be security-significant and should be caught by the deployment isolation checks.

## 4 How the parts talk

Service calls use HTTP with JSON bodies; NumPy arrays are base64-encoded inline. This transport is suitable for the current bounded fixtures, not an unlimited large-dataset transport. There is no SSH or shared writable disk between the agent and trusted evidence services. The gateway records structured requests and claims; it does not retain or hash every raw HTTP message. Claims bind verdicts to validated SHA-256 subjects and materials. Table 2 lists each link, who starts it, what it carries, and what it forbids.

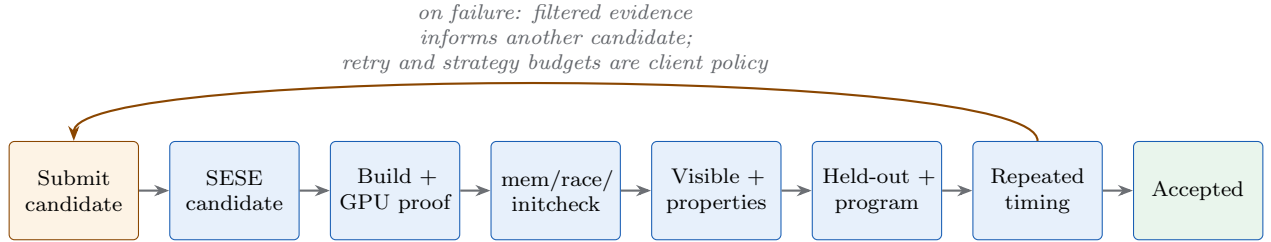
| Link                                                                                                                               | What crosses                                                                                                                                                                                   | What is forbidden                                                                                                                                                                                       |
|------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Agent → Gateway<br>/table /status<br>/claims /submit<br>/run                                                                       | The agent reads filtered status and receipts, asks to submit its configured working copy, and requests named actions.                                                                          | The request cannot choose a repository, filesystem path, component endpoint, or undeclared configuration key. Submitted paths outside the reviewed allow-list are rejected.                             |
| Agent → Model                                                                                                                      | The prompt, and the model’s reply.                                                                                                                                                             | No held-out arrays, oracle filesystem, repository, or ledger are mounted into the agent. Prompt content and provider credentials remain an external-service exposure to manage.                         |
| Gateway → Builder<br>/v1/build /v1/run<br>/v1/capture<br>/v1/sanitize<br>/v1/properties<br>/v1/mutate<br>/v1/time<br>/v1/artifacts | Out: the committed tree, manifest-selected targets, reviewed strategy settings, and selected inputs. In: bounded logs and protected observations, including executable identities and timings. | Submitted Makefiles run, but cannot choose compiler flags supplied by the gateway or write protected observation files. Submitted code runs in networkless disposable jobs without service credentials. |
| Gateway → Oracle<br>/v1/compare<br>/v1/policy<br>/v1/dataset/<br>holdout/inputs                                                    | Out: the output arrays and which dataset. In: pass or fail, and the pervariable error for the visible set only.                                                                                | There is no write path. Tolerances cannot change over the wire. For the held-out set, only pass or fail comes back, never the detailed error.                                                           |
| Gateway → Ledger /<br>repo                                                                                                         | Immutable candidate commits; append-only request and claim lines; saved content-addressed evidence.                                                                                            | No other container can see these volumes.                                                                                                                                                               |

**Table 2:** The links between parts. The agent initiates only gateway calls; the gateway alone initiates builder and oracle calls. The two links that matter most for safety are the one to the agent and the one to the oracle. Neither one can carry an order to change how the code is judged.

The receipt filter is the most important response boundary. The gateway returns full diagnostic detail only for predicate types whose registry permits it. Held-out comparison receipts are verdict-only, while full details remain in the trusted ledger for review. This prevents direct disclosure of held-out arrays, but repeated pass/fail queries still leak information; the current implementation has no held-out query budget.

## 5 The loop

Figure 2 shows the implemented porting gates. The gateway action table enforces prerequisites and phase membership; the client chooses when to request the next eligible action. Automatic retry caps and automatic movement through a strategy ladder were part of the original proposal and are not implemented by the gateway. A build that passes is not enough. Each candidate must receive a new tree-scoped SESE verdict, run on the GPU, pass all three sanitizer modes, match visible and held-out answers, preserve whole-program outputs, and complete valid repeated timing. A code that declares properties must pass them as well.



**Figure 2:** The implemented porting evidence chain. Held-out comparison precedes whole-program regression and timing. Acceptance is a ledger decision over all required current claims, not a separate execution stage.

Onboarding is a separate phase. It validates the manifest; builds under the baseline and porting strategies; captures, replays, and checks deterministic datasets; times the harness; compares the onboarded CPU program with a preserved original reference; mutation-tests the harness; and runs declared properties. All nine claims are tree-scoped and required before promotion.

## 6 Evidence identity and currentness

Ledger schema version 2 distinguishes the object being judged from the inputs to that judgment. Subjects include candidate trees, frozen file sets, capture sets, binaries, policies, references, executor identities, and oracle identities. File-set hashes use a domain tag, item count, and length-delimited normalized paths and contents; claims with malformed hashes are rejected.

Every current claim names the evidence-policy implementation, candidate and baseline strategies, manifest, tolerance and property files when present, visible dataset, and original-reference contract. Live gateway claims also bind the reviewed or observed executor identity and, for porting comparisons, the oracle identity. Claims after a build carry the complete binary cohort from the current passing build. The gateway rechecks protected artifact records before reuse; if a builder workspace was lost, it rebuilds and proceeds only when the executable digests reproduce. Offline status and promotion apply the same material requirements. Earlier claims remain history but become stale evidence.

A submission becomes an immutable Git commit before a check reads it. The SESE claim is attached to that candidate tree, so every candidate edit requires a fresh analysis. Its recorded allow-list

may authorize which files a later submission changes, but it does not make the earlier SESE verdict apply to the new tree. Porting and onboarding actions cannot be mixed across phases.

## 7 What the controls establish, and what they do not

The demonstration places the agent under real controls. The boundaries below state the narrower claims those controls support.

**It cannot edit the sealed comparison basis.** Held-out expected answers, the oracle comparator, and its deployed tolerance policy live in the read-only oracle image on a network the agent cannot reach. Visible datasets, manifests, properties, and reference contracts are separately hashed materials; changing one invalidates dependent claims. Submitted property code still requires human review: isolation proves what process ran, not that its assertions are scientifically sufficient.

**It cannot replace protected observations with its own report.** The submitted tree may include a Makefile, especially during onboarding. Compiler and link flags come from a reviewed strategy, while protected tracing records compiler execution and protected profiling records GPU activity. Executable digests bind later jobs to the passing build. This does not prove complete binary provenance: a malicious Makefile could compile legitimately and then replace an output. Build recipes and final provenance remain review obligations.

**It has no direct route to heldout data.** The heldout data sits in one place, the oracle, on a private network. When the agent’s code finally runs, it runs in the builder with no network at all, so it cannot phone home. The heldout inputs reach the code only through a gateway-authorized comparison after visible regression has passed. The receipt exposes a verdict rather than arrays or per-variable errors. Because repeated queries are not currently budgeted, this is a confidentiality boundary with a known adaptive-query leak, not a claim that the held-out set reveals no information.

We are honest about the limit. On one computer, these walls constrain a *misbehaving submitted process* within the container threat model. The Docker daemon, builder supervisor, job image, host kernel, and GPU driver are in the trusted computing base. The controls are not a virtual-machine boundary and do not stop a kernel, daemon, or driver exploit. Moving the oracle to another machine is proposed hardening, not an already demonstrated property.

## 8 Swapping the model

**Original proposal and current implementation.** The design called for interchangeable model adapters with a patch-only interface. The current agent uses the Pi coding session and its provider configuration, while the stable system boundary is the gateway tool API and configured working copy. Model switching is therefore largely a client concern, but “one config line” has not been established as a system-level guarantee.

The proposed adapter design was:

- The Claude adapter can run a full editing agent inside the container, then take the git diff. This keeps Claude’s strong multifile editing while still returning only a patch.
- The Gemini adapter and the localmodel adapter both speak a standard chat API and are asked to emit a diff.

The proposal expected one OpenAI-style adapter to cover Gemini and local servers. That adapter

layer is not part of the current trusted gateway. A resident local model may also contend with the builder for GPU resources during timing, so a deployment using one needs separate hardware or explicit resource scheduling.

## 9 Build our own harness, or use a framework?

**Design rationale.** The proposal chose a small explicit outer loop rather than an agent framework. A framework like LangGraph or AutoGen is built to manage flexible, changing control flow. Our need is the opposite. The implemented gateway provides the fixed phase and precondition table and a record a reviewer can inspect. Retry counts and strategy selection remain client policy rather than a three-hundred-line autonomous orchestrator. A framework would also sit on the trust boundary, and any clever feature it adds, like a tool loop the model did not expect, is a hole in the wall. We keep the trusted core small, plain, and fully ours.

We still use provider libraries, but only inside the adapters, where they are a private detail. The one exception worth naming is that the Claude adapter may use Claude’s own agent tools inside its container. That is safe, because the container is already untrusted and already walled off.

## 10 The GPU container

The builder supervisor is a long-running service, while each submitted build, run, capture, sanitizer, property, mutation, profiler, or timing command runs in a disposable sibling container. The supervisor deliberately holds the Docker control socket to create and destroy those jobs. That socket is root-equivalent and places the supervisor in the trusted computing base. It is not mounted into the gateway, agent, or submitted jobs. Jobs use no network, no service token, a read-only image, dropped capabilities, an unprivileged submitted process, and only selected subdirectories from the builder work volume.

The builder image is based on the NVIDIA HPC SDK image. It ships the `nvfortran` compiler, the `computesanitizer`, and the `nsys` profiler together. So the build gate, the GPU proof, the sanitizer gate, and timing use one reviewed image. The supervisor reports the resolved image and executor identities; claims depend on them. Rebuilding elsewhere still depends on a compatible NVIDIA driver, Docker behavior, architecture, and tool availability, and must be qualified on the target host.

## 11 Requirements

The architecture is evaluated against these requirements. Wording below states what the repository currently enforces and where qualification is still needed.

- **Reproducibly deployable.** Docker Compose defines the services, networks, mounts, and reviewed images. Each target NVIDIA host still needs a compatible driver and container toolkit and must pass the qualification run.
- **Isolated.** The agent shares no network and no disk with the builder, oracle, repository, or ledger. The gateway reads the working copy read-only. Only the trusted builder supervisor holds the Docker socket; submitted jobs do not. The held-out data lives in the oracle image.

- **Least message.** Agent receipts may name the held-out check and reveal its verdict, but cannot carry its arrays or per-variable diagnostics. This is enforced by the predicate receipt policy. Repeated verdicts remain a leakage channel until a query budget is enforced.
- **Deterministic gates.** The action table, phase checks, prerequisite resolution, framed hashes, and deterministic duplicate lookup are fixed. Property searches record a signed 64-bit seed. Model behavior, scheduling, compiler output, and timing are not thereby deterministic.
- **Auditable.** The ledger is append-only and records structured requests and version-2 claims. Claims bind subjects to materials and retain structured detail or content-addressed artifacts. This is not a byte-for-byte transcript of every HTTP message.
- **Honest speed.** Timing accepts 5–100 requested repetitions, validates every returned duration and output, and compares every port repetition with the stored program baseline under the reviewed tolerances. Workload representativeness and host contention remain review and deployment obligations.
- **Bounded action inputs.** Timing repetitions are 5–100; property example ceilings are 100–10,000; mutation limits are 1–10,000; seeds are signed 64-bit integers. These are per-action bounds. The gateway does not enforce an overall retry cap or held-out-query budget.
- **Stable service contracts.** Model providers, remote builders, or a remote oracle can reuse the present interfaces, but such deployments need separate credentials, TLS, storage, failure handling, and qualification.

## 12 Implemented now, and proposed later

**Implemented now.** Compose supplies the agent, gateway, builder supervisor, oracle, isolated networks, and persistent state. The gateway serves onboarding and porting phases and evidence-aware status. All three sanitizer modes are acceptance requirements. Authentication is a shared bearer token and traffic is plain HTTP on private Compose networks. Arrays remain inline JSON. The repository includes CPU boundary qualification; GPU execution, profiler, sanitizer, and performance claims require a full qualification run on the actual NVIDIA host.

**Proposed later.** Candidates include provider and local-model adapters; an outbound proxy that limits where the agent can connect; the ledger as its own service; TLS and per-service tokens; a held-out query budget; stronger final-binary provenance; and a cluster split with the oracle on its own machine. The existing HTTP contracts reduce migration work but do not make those changes automatic.

The current boundary combines missing network routes, narrow messages, immutable candidate commits, versioned evidence dependencies, and protected observation in disposable jobs. Its claims remain limited by the trusted host stack and by the scientific review obligations recorded with each check.